# Trivy (Misconfiguration Scan)

Target: orangehrm/orangehrm (main)
Project: orangehrm
Total Issues: 2 (Critical: 0 | High: 1 | Medium: 0 | Low: 1)

| | | | |
|---|---|---|---|
| **Files scanned** | 1 | **Trivy version** | 0.76.1 |
| **Checks passed** | 25 | **Checks failed** | 2 |

## SCANNED FILES

Trivy evaluates each Dockerfile against security best-practice checks (policy-as-code). **Pass** = check satisfied, **Fail** = misconfiguration that needs remediation.

| File | Pass | Fail |
|---|---|---|
| `Dockerfile` | 25 | **2** |

## HIGH (1)

HIGH

### Image user should not be 'root'

DS-0002

**Location** `Dockerfile (file-level: applies to the whole file)`

**Finding**

Specify at least 1 USER command in Dockerfile with non-root user as argument

**Description**

Running containers with 'root' user can lead to a container escape situation. It is a best practice to run containers as non-root users, which can be done by adding a 'USER' statement to the Dockerfile.

**Remediation**

Add 'USER <non root user name>' line to the Dockerfile

**Remediation example**

```
# Alpine:
RUN addgroup -S app && adduser -S app -G app
USER app
```

**References**

- Reference
- Reference

## LOW (1)

LOW

### No HEALTHCHECK defined

DS-0026

**Location** `Dockerfile (file-level: applies to the whole file)`

**Finding**

Add HEALTHCHECK instruction in your Dockerfile

**Description**

You should add HEALTHCHECK instruction in your docker container images to perform the health check on running containers.

**Remediation**

Add HEALTHCHECK instruction in Dockerfile

**Remediation example**

```
HEALTHCHECK --interval=30s --timeout=5s --retries=3 \
  CMD curl -f http://localhost:<port>/health || exit 1
```

**References**

- Reference
- Reference

## PASSED CHECKS — Dockerfile (25)

| ID | Check | Severity |
|---|---|---|
| DS-0001 | ':latest' tag used | Medium |
| DS-0004 | Port 22 exposed | Medium |
| DS-0005 | ADD instead of COPY | Low |
| DS-0006 | COPY '--from' referring to the current image | Critical |
| DS-0007 | Multiple ENTRYPOINT instructions listed | Critical |
| DS-0008 | Exposed port out of range | Critical |
| DS-0009 | WORKDIR path not absolute | High |
| DS-0010 | RUN using 'sudo' | Critical |
| DS-0011 | COPY with more than two arguments not ending with slash | Critical |
| DS-0012 | Duplicate aliases defined in different FROMs | Critical |
| DS-0013 | 'RUN cd ...' to change directory | Medium |
| DS-0014 | RUN using 'wget' and 'curl' | Low |
| DS-0015 | 'yum clean all' missing | High |
| DS-0016 | Multiple CMD instructions listed | High |
| DS-0017 | 'RUN <package-manager> update' instruction alone | High |
| DS-0019 | 'dnf clean all' missing | High |
| DS-0020 | 'zypper clean' missing | High |
| DS-0021 | 'apt-get' missing '-y' to avoid manual input | High |
| DS-0022 | Deprecated MAINTAINER used | High |
| DS-0023 | Multiple HEALTHCHECK defined | Medium |
| DS-0025 | 'apk add' is missing '--no-cache' | High |
| DS-0027 | 'microdnf clean all' missing | High |
| DS-0029 | 'apt-get' missing '--no-install-recommends' | High |

| ID | Check | Severity |
| --- | --- | --- |
| DS-0030 | WORKDIR should not be mounted on system dirs | High |
| DS-0031 | Secrets passed via `build-args` or envs or copied secret files | Critical |